

WHITE BAND ASSOCIATES
Internship Programme | Ethical Hacking Track

TASK 02

Research Notes

Network Scanning & Service Enumeration

Prepared By	Pratiksha Vishwakarma
Task	Ethical Hacking Task 02
Date	June 26, 2026
Topic	Nmap, Port Scanning, Service Enumeration
Classification	Study Notes — Internal Use Only

1. What is Network Scanning & Enumeration?

Network scanning is the second phase of the ethical hacking lifecycle, performed after passive reconnaissance. Where reconnaissance gathers information without touching the target, scanning actively sends packets to the target system to discover which hosts are alive, which ports are open, what services are running, and what operating system the target is using.

Enumeration goes one step further — it extracts specific, detailed information from the discovered services, such as software versions, user accounts, shared resources, and banners. Together, scanning and enumeration form the foundation of any penetration test because they define the attack surface that an ethical hacker will investigate.

⚠ IMPORTANT Scanning must only be performed on systems you own or have explicit written permission to test. Unauthorised scanning is illegal in most countries.

1.1 The Five Phases of Ethical Hacking

#	Phase	Description
1	Reconnaissance	Passive information gathering — OSINT, WHOIS, DNS lookups. No direct contact with target.
2	Scanning & Enumeration	Active probing — port scanning, service detection, OS fingerprinting. This is Task 02.
3	Gaining Access	Exploiting discovered vulnerabilities to gain a foothold on the target system.
4	Maintaining Access	Installing backdoors or persistence mechanisms to retain access after reboots.
5	Covering Tracks	Removing logs, altering timestamps, hiding evidence of the intrusion.

2. Nmap — Network Mapper

Nmap (Network Mapper) is the industry-standard open-source tool for network discovery and security auditing. It was created by Gordon Lyon (Fyodor) in 1997 and is now maintained by the Nmap Project. It is pre-installed on Kali Linux and is used by penetration testers, system administrators, and security researchers worldwide.

 **KEY CONCEPT** Nmap is not just a port scanner — it is a complete network intelligence platform capable of host discovery, service detection, OS fingerprinting, vulnerability scanning (via scripts), and network mapping.

2.1 How Nmap Works

Nmap constructs and sends specially crafted packets to the target and analyses the responses. The type of packet sent depends on the scan technique selected. By observing how the target responds — whether it sends back a SYN-ACK, RST, ICMP unreachable, or nothing at all — Nmap determines the state of each port and builds a picture of the target's network profile.

2.2 Port States in Nmap

State	Meaning
Open	A service is actively listening on this port and accepting connections.
Closed	The port is accessible (the host responds) but no service is listening. Kernel sends a TCP RST.
Filtered	A firewall or packet filter is blocking the probe. Nmap receives no response or an ICMP error.
Unfiltered	The port is accessible but Nmap cannot determine if it is open or closed (ACK scan result).
Open Filtered	Nmap cannot determine whether the port is open or filtered — no response received.
Closed Filtered	Nmap cannot determine whether the port is closed or filtered.

2.3 Key Nmap Flags Used in This Task

Flag	Name	What it does
(none)	Default TCP SYN Scan	Scans top 1,000 ports. Sends SYN packets and checks for SYN-ACK or RST responses.
-sV	Version Detection	Probes open ports with service-specific payloads to identify software name and version.
-O	OS Detection	Uses TCP/IP stack fingerprinting to identify the target operating system. Requires root/sudo.
-sC	Default Script Scan	Runs Nmap's default NSE scripts for additional enumeration (banners, vulnerabilities, etc).
-sS	SYN Stealth Scan	Half-open scan — sends SYN, does not complete the TCP handshake. Harder to detect in logs.
-sU	UDP Scan	Scans UDP ports. Slower than TCP scans. Used for services like DNS (53) and SNMP (161).
-p	Port Specification	Specify ports: -p 80, -p 1-1000, -p- (all 65535 ports).
-A	Aggressive Scan	Combines -sV, -O, -sC and traceroute into one comprehensive scan.
-oN / -oX	Output Formats	-oN saves plain text; -oX saves structured XML for import into other tools.

--version	Tool Version	Displays Nmap version and compilation details. Used to verify the installation.
------------------	---------------------	---

3. TCP vs UDP — Understanding the Protocols

Most network services operate over either TCP or UDP. Understanding the difference between them is fundamental to interpreting Nmap scan results, because the two protocols behave very differently when probed.

3.1 TCP — Transmission Control Protocol

TCP is a connection-oriented protocol. Before any data is exchanged, both parties must complete a three-way handshake: the client sends a SYN packet, the server responds with SYN-ACK, and the client replies with ACK. This handshake makes TCP reliable — data is guaranteed to arrive in order, and lost packets are retransmitted. This also makes TCP easy for Nmap to scan, because the handshake responses (SYN-ACK for open, RST for closed) clearly indicate port state.

 **TIP** TCP SYN scan (-sS) is the default and most popular Nmap scan type. It sends only a SYN and waits for the response — it never completes the handshake, making it faster and less detectable than a full connect scan.

3.2 UDP — User Datagram Protocol

UDP is a connectionless protocol — there is no handshake. Data is sent without confirming the recipient is ready, and there is no built-in delivery guarantee. This makes UDP faster and lighter than TCP, which is why time-sensitive services like DNS, DHCP, VoIP, and video streaming use it. However, scanning UDP is much harder because many UDP ports simply do not respond to probes, making it difficult to distinguish between open and filtered states.

Feature	TCP	UDP
Connection	Connection-oriented (3-way handshake)	Connectionless (no handshake)
Reliability	Guaranteed delivery, ordered packets	No guarantee — fire and forget
Speed	Slower due to handshake overhead	Faster — minimal overhead
Nmap Scan Speed	Fast — clear open/closed responses	Slow — timeouts needed to detect state
Common Services	HTTP, SSH, FTP, SMTP, RDP	DNS, DHCP, SNMP, VoIP, NTP
Nmap Default	Yes — scanned by default	No — requires -sU flag

4. Port Scanning Techniques

Nmap supports multiple scanning techniques, each suited to different scenarios. Choosing the right scan type affects speed, stealth, and the quality of results.

4.1 TCP SYN Scan (-sS) — Half-Open Scan

The default and most widely used scan. Nmap sends a SYN packet and waits for a response. If it receives SYN-ACK the port is open, if it receives RST the port is closed. Nmap never completes the three-way handshake, so the connection is never fully established. This means the scan is faster, uses fewer resources, and is less likely to appear in application logs (though it will still appear in firewall logs).

 **NOTE** This is the scan performed in Part B of this task — nmap localhost uses SYN scan by default when run as root.

4.2 TCP Connect Scan (-sT) — Full Connect

Completes the full three-way handshake for each port. This is the scan type used when root privileges are not available. It is slower and more detectable than SYN scan because the OS fully logs completed connections, but it is the only option for unprivileged users.

4.3 UDP Scan (-sU)

Sends UDP packets to target ports. If an ICMP 'port unreachable' error is returned, the port is closed. If there is no response, the port is considered open or filtered. UDP scanning is significantly slower than TCP — a full UDP scan of 65,535 ports can take hours. Common UDP targets include DNS (53), SNMP (161), NTP (123), and DHCP (67/68).

4.4 ACK Scan (-sA) — Firewall Mapping

Sends TCP ACK packets rather than SYN. This is not used to determine if ports are open — it is used to map firewall rules. If the port responds with RST, it is classified as unfiltered (the packet reached the host). No response or ICMP error means it is filtered. Useful for understanding what a firewall allows through.

4.5 Stealth / Evasion Scans

Flag	Scan Type	How it works
-sN	NULL Scan	Sends packets with no TCP flags set. Open/filtered ports do not respond; closed ports reply with RST.
-sF	FIN Scan	Sends FIN packets. Same logic as NULL scan. Bypasses some non-stateful firewalls.
-sX	Xmas Scan	Sends FIN, URG, and PUSH flags set — 'lit up like a Christmas tree'. Same response logic.
-sI	Idle Scan	Uses a zombie host to perform the scan, hiding the true source IP. Most stealthy technique.

5. Service Enumeration & Banner Grabbing

Once open ports are identified, the next step is to determine exactly what software is listening on each port. This is called service enumeration. The goal is to gather enough detail to identify known vulnerabilities in the specific version of the software found.

5.1 Service Version Detection (-sV)

Nmap's -sV flag sends a series of probe strings to each open port and compares the responses against a database of over 11,000 known service signatures (nmap-service-probes). The result is a version string such as 'OpenSSH 9.6 (protocol 2.0)' or 'Apache httpd 2.4.62 ((Debian))'. This version string can then be searched in CVE databases (such as NVD or Exploit-DB) to find known vulnerabilities.

✔ **TIP** Version detection adds significant scan time because Nmap must wait for responses to each probe. Combining with -T4 (aggressive timing) speeds this up on reliable networks.

5.2 Banner Grabbing

Many services announce themselves when a connection is made by sending a 'banner' — a plain-text string containing the software name, version, and sometimes OS details. Banner grabbing is the act of capturing this string. It can be done with Nmap (-sV), with netcat, or with telnet.

Example using netcat:

```
$ nc -v 192.168.1.10 80
HTTP/1.1 400 Bad Request
Server: Apache/2.4.62 (Debian)
```

The 'Server:' header above is a banner. It reveals the web server software and version without needing any credentials or exploitation.

5.3 NSE — Nmap Scripting Engine (-sC / --script)

Nmap includes a powerful scripting engine (NSE) that allows hundreds of automation scripts to run against discovered services. Scripts can perform tasks such as grabbing HTTP headers, testing for default credentials, checking for known vulnerabilities, enumerating SMB shares, and much more.

Script Category	Purpose
default (-sC)	Safe, commonly useful scripts run automatically during standard scans.
vuln	Check for known vulnerabilities: <code>nmap --script vuln <target></code>
auth	Test for default or empty credentials on services.
brute	Attempt brute-force login on discovered services.
discovery	Gather additional information about the network and services.
safe	Scripts that are unlikely to crash services or cause disruption.

6. Operating System Fingerprinting

OS fingerprinting is the technique of remotely identifying the operating system of a target without having any account or access to the system. Nmap performs active OS fingerprinting by sending a series of carefully designed probes and analysing how the target's TCP/IP stack responds to them.

6.1 How OS Fingerprinting Works

Every operating system implements the TCP/IP stack slightly differently. These differences — though subtle — create a unique fingerprint. Nmap analyses the following characteristics in the responses it receives:

- TCP ISN (Initial Sequence Number) generation patterns
- TCP window size and scaling options in SYN packets
- IP TTL (Time to Live) initial values
- IP DF (Don't Fragment) bit behaviour
- TCP options ordering and values (timestamp, MSS, SACK)
- ICMP response behaviour and error message quoting

Nmap compares the collected fingerprint against its OS detection database (nmap-os-db), which contains fingerprints for thousands of operating systems and versions. The result is a ranked list of the most likely OS matches.

⚠ IMPORTANT OS detection requires at least one open AND one closed TCP port to produce a reliable result. With all ports closed (as in this task), fingerprinting returns inconclusive results.

6.2 Why OS Detection Matters in Penetration Testing

Reason	Explanation
Exploit Selection	Many exploits are OS-specific. Knowing the OS narrows down which CVEs to investigate.
Patch Level Awareness	Older OS versions may be end-of-life and unpatched, making them prime targets.
Service Prediction	Certain services run by default on specific OS versions (e.g. IIS on Windows, Apache on Linux).
Privilege Escalation	Local privilege escalation exploits are kernel/OS version specific.
Network Topology	OS types reveal the network architecture — Windows domains, Linux servers, embedded devices.

7. Common Ports — Quick Reference

The following is a consolidated quick-reference table for the most important ports encountered in penetration testing. Every security professional should be able to recall these from memory.

Port	Service	Proto	Used For	Risk Level	Key Risk
20/21	FTP	TCP	File transfer	High	Plaintext credentials, anonymous login
22	SSH	TCP	Encrypted remote access	Medium	Brute-force on weak passwords
23	Telnet	TCP	Unencrypted remote access	Critical	Everything in plaintext — obsolete
25	SMTP	TCP	Email sending/relay	Medium	Open relay, user enumeration
53	DNS	TCP/UDP	Name resolution	Medium	Zone transfer, DNS poisoning
80	HTTP	TCP	Web pages (unencrypted)	High	XSS, SQLi, session hijacking
110	POP3	TCP	Email retrieval	Medium	Plaintext credentials
143	IMAP	TCP	Email access on server	Medium	Plaintext by default
443	HTTPS	TCP	Encrypted web traffic	Low	Weak TLS config, cert errors
445	SMB	TCP	Windows file sharing	Critical	EternalBlue, lateral movement
3389	RDP	TCP	Windows remote desktop	Critical	BlueKeep, brute-force
8080	HTTP-Alt	TCP	Alternate web/proxy port	Medium	Often unfiltered by firewalls
3306	MySQL	TCP	Database access	High	Exposed DB, default credentials
21	FTP	TCP	File transfer control	High	Weak auth, anonymous access

8. Vulnerability Assessment Basics

Once scanning and enumeration are complete, the collected information is used to identify vulnerabilities — weaknesses in the target system that could be exploited by an attacker. This step bridges the gap between reconnaissance and actual exploitation.

8.1 What is a Vulnerability?

A vulnerability is any weakness in a system, application, or network that could be exploited to compromise confidentiality, integrity, or availability. Vulnerabilities can arise from software bugs, misconfiguration, weak credentials, missing patches, design flaws, or insecure protocols.

8.2 CVE — Common Vulnerabilities and Exposures

CVE is a standardised list of publicly known cybersecurity vulnerabilities, maintained by MITRE Corporation. Each vulnerability is assigned a unique identifier in the format CVE-YEAR-NUMBER (e.g. CVE-2019-0708 for BlueKeep). The National Vulnerability Database (NVD) provides additional details including a CVSS severity score.

✓ **TIP** After running `nmap -sV` and obtaining a version string such as 'Apache 2.4.49', you would search that version on <https://nvd.nist.gov> or <https://www.exploit-db.com> to find known CVEs.

8.3 CVSS — Common Vulnerability Scoring System

Score Range	Severity	Meaning
0.0	None	No vulnerability or informational finding only.
0.1 – 3.9	Low	Minimal impact. Difficult to exploit or requires local access.
4.0 – 6.9	Medium	Moderate impact. May require user interaction or specific conditions.
7.0 – 8.9	High	Significant impact. Can lead to data breach or system compromise.
9.0 – 10.0	Critical	Severe. Remote code execution or complete system takeover possible.

8.4 From Scan to Vulnerability — The Workflow

- Run `nmap -sV <target>` to obtain service versions
- Note each service name and version (e.g. OpenSSH 7.4, Apache 2.4.49)
- Search the version on NVD (nvd.nist.gov) or Exploit-DB ([exploit-db.com](https://www.exploit-db.com))
- Review CVEs — check CVSS score, attack vector, and whether a public exploit exists
- Cross-reference with Metasploit: search `<service name>` in `msfconsole`
- Document findings with CVE ID, severity, and recommended remediation

🔑 **KEY CONCEPT** Not every open port is vulnerable. The goal is to identify which specific versions have known weaknesses, not to assume everything is exploitable.

9. Key Terms & Glossary

Term	Definition
Attack Surface	The total set of points on a system where an attacker could attempt to enter or extract data.
Banner Grabbing	Capturing the service banner sent by a server upon connection to identify software and version.
CVE	Common Vulnerabilities and Exposures — a standardised ID for publicly known security vulnerabilities.
CVSS	Common Vulnerability Scoring System — a numerical score (0–10) reflecting vulnerability severity.
Enumeration	Extracting detailed information from discovered services, such as versions, users, and shares.
Fingerprinting	Identifying the OS or software based on behavioural patterns in network responses.
Firewall	A network security device that monitors and controls incoming and outgoing network traffic.
IDS / IPS	Intrusion Detection / Prevention System — monitors for and can block suspicious network activity.
Loopback Interface	A virtual network interface (127.0.0.1) that routes traffic back to the same machine. Used for local testing.
Nmap	Network Mapper — an open-source tool for network discovery, port scanning, and security auditing.
NSE	Nmap Scripting Engine — allows custom and built-in scripts to run against scan targets.
Open Port	A port on which a service is actively listening and accepting incoming connections.
Penetration Testing	An authorised simulated cyberattack on a system to identify exploitable vulnerabilities.
Port	A logical endpoint for network communication. Ranges from 0–65535. Well-known ports: 0–1023.
Reconnaissance	The first phase of ethical hacking — gathering information about the target passively.
RST Packet	A TCP Reset packet — sent by a host to immediately terminate a connection or indicate a closed port.
Service Enumeration	Identifying the specific services and versions running on discovered open ports.
SYN Packet	The first packet in a TCP three-way handshake, used to initiate a connection.
TCP	Transmission Control Protocol — reliable, connection-oriented protocol with guaranteed delivery.
TCP SYN Scan	The default Nmap scan — sends SYN packets and reads responses without completing the handshake.
TTL	Time to Live — a field in IP packets that limits how many hops a packet can travel before being discarded.
UDP	User Datagram Protocol — fast, connectionless protocol with no delivery guarantee.

Vulnerability	A weakness in software, configuration, or design that can be exploited to cause harm.
----------------------	---